

Cloud infrastructures: 3.1

Cloud Responsibility Matrix:

IaaS: Infrastructure as a Service

PaaS: Platform as a Service

SaaS: Software as a Service

Security should be well document

- Matrix of responsibilities

These responsibilities can vary

- Different obligations

Hybrid Considerations:

Hybrid Cloud:

More than a Public/Private Cloud

- Adds additional complexity

Network Protection Mismatch

- Auth across all Platforms

- Server Settings

Different Security Monitoring

Data Leakage

- Shared across the internet

Third Party-Vendors in the Cloud:

You, the cloud provider, and third parties

- Infrastructure technologies

Ongoing Vendor Risk assessment

Include a third party impact for incident response

Constant Monitoring

Infrastructure as code:

Define an infrastructure

- Define Servers, Network, and apps as Code

Modify the infrastructure and create versions

Use the description code to build other application instances

- Fundamental Building block

Serverless Architecture:

Function as a Service (FaaS)

Applications are separated into individual, autonomous functions

Remove the operating system from the equation

Developer still creates server side logic.

May be event triggered and efficient

- May only be run for one event

Microservices and APIs:

Monolithic Applications: One big app that does it all

Application contains all decision Making Process

- UI
- Business logic
- Data Input/output

Code Challenges

- Large Codebase
- Change control

Microservices + APIs

APIs: Application Programming Interfaces

API is the 'glue' for microservices

- Work together to act as the application

Scalability is good

Resilient: Outages are contained

Security & Compliance: Containment built in.

Network Infrastructure Concepts: 3.1

Physical isolation:

Devices are Physically Separate

- Air gap between A and B

Must be connected to provide communication

- Direct connect, or another switch or router

Web Servers in one rack

Customer A on one Switch, Customer B on another

Logical Segmentation with VLANs: Separates logically yet still Physically Connected

Cannot communicate between VLANs without Layer 3 device

SDN (Software defines Networking)

Networking devices have different functional Planes or operation

- Data, Control, and Management

Split the functions into separate logic units

- Extends the functionality and Management of a single device

- Perfectly built for cloud

Software Defined Network (SDN)

Infrastructure Layer / Data Plane

- Process the Network frames + packets
- Forwarding, trunking, encapsulating, NAT

Control Layer / Control Plane:

- Manages actions of the data plane
- Routing tables, Session tables, NAT tables
- Dynamic Routing Table Updates

Application Layer / Management Plane:

- Configure + Manage the device
- SSH, telnet, API

Other infrastructure concepts: 3.1

Attacks can happen anywhere:

Two categories for IT security

- On Premise / Cloud

Cloud Based Security is Centralized and Costs less

- No dedicated hardware, no data center to secure

- Third party handles all

On-Premise Puts the burden of security and cost on the client

On-Premises Security:

Customize Your own Security Posture

On-Site IT team can manage security better

- Extensive

Local team maintains uptime + Availability

Security changes can take time

- New equipment, configs... etc...

Centralized vs. Decentralized:

Most organizations are physically decentralized

- Many locations, cloud servers, OS, etc

Difficult to Manage + Protect so many diverse systems

A Centralized approach

- Correlated Alerts
- Consolidated log file analysis
- Comprehensive system status and maintenance/patching

Not Perfect - Single point of failure.

- Worse scalability

Virtualization:

Run many different OS on the same system

Each application instance has its own OS

Hypervisor: Manages all resources, bottom level OS

Infrastructure: Device itself

Application Containerization:

Container: Contains everything you need to run an app, code and dependencies

An isolated process in a server: Self container

Container image: Standard for portability

- Secure separation between devices

IoT (Internet of things)

Sensors

- Heating Cooling & Lighting

Smart Devices

- Home Automation, Video doorbells

Wearable Tech

- Smart Watches

Facility Automation

- Temperature, Air Quality, Lighting

Weak Defaults:

- IoT Managers are NOT Security Professionals

SCADA / ICS:

Supervisory Control and Data Acquisition System

- Large Scale, Multi-site Industrial Control Systems (ICS)

PC Manages equipment: Power generation, Refining, Management controls

Requires extensive Segmentation

- No access from the outside

RTOS (Real Time Operating System)

An Operating system with a deterministic Processing Schedule

- No time to wait for other processes
- Industrial equipment, automobiles

Extremely Sensitive to Security Issues

- Need to always be available
- Very Self Contained

Embedded system:

Hardware and Software designed for a specific function

- Or to operate as a part of a larger system

Is built for one specific purpose

- Optimized for this task

Examples:

Traffic Lights

Digital Watches

Medical Imaging System

High Availability:

Multiple Systems doesn't imply availability

HA (Always available)

- Always on, always Available

May include many different components working together

- Active / Active

Higher Availability → Higher costs

- There ALWAYS another contingency you could add

Need to justify cost

Infrastructure Considerations: S.I

Availability:

System Uptime

- Access data, complete transaction

Balancing Act With Security

We Spend a Lot of Time and Money

Availability is a Metric of Availability

Resilience:

Eventually, Something Will Occur

- Can You Maintain Availability?

Based On Many Different Variables

- The Root Cause
- Replacement Hardware Installation
- Software Patches

Commonly referred as MTTR

- Mean Time To Repair

Cost:

Important basis

- How much?

Initial Installation

- Varies across Platforms

Ongoing Maintenance

- Annual Ongoing cost

Replacement / Repair costs

Tax implications

Responsiveness:

Request information: How fast do we get a response

Especially important for Interactive Applications

Speed is Paramount

- All Parts contribute
- There is Always a bottleneck

Scalability:

How quickly can we increase / decrease capacity: Elasticity

Always a resource challenge; Money

Scale based on demand

Needs to include Security Monitoring

Ease of Deployment:

An application has many moving parts

- Web server, database, caching server, firewall, etc

This may be an involved process

- Hardware resources, cloud budgets, charge control

This may be very simple

Important to consider during the Product Management phase

Risk Transference:

Many methods to minimize risk

- Transfer risk to third party

Cybersecurity Insurance

- Attacks and downtime can be covered

- Popular with rise of ransomware

Reduce internal losses

Protect from legal issues with customers

Ease Of Recovery:

Something will go wrong

- Time is Money

Malware Infection

- Reboot OS from system from original media - 1 hr

- Reboot from ColdFire Image - 10 Min

Patch Availability:

Software is sparsely static

This is often the first task after installation

Most companies have regular updates

Some companies rarely patch - Bad idea

Inability to Patch:

What if patching wasn't an option?

- Happens more often than you think

Embedded systems

- HVAC Controls

- Time Clock

May need additional security

Power:

A foundational element

- Can receive extensive engineering

Overall Power requirements

Primary Power Provider

Backup Services

- UPS (Uninterruptible Power Supply)
- Generator

Compute:

An applications heavy lifting

The Compute Edge

- More Options in the cloud

May be limited to a single processor

Use multiple CPUs across multiple clouds

- Additional Complexity + Enhanced Scalability?

Secure Infrastructures: 3.2

Every Network is different, some similarities still

Firewalls: Segmenting Network, Trusted from Untrusted

Other services may have their own security technologies

- Honeypots, jump server, load balancer, sensor

Security Zones:

- Zone Based Security technology

Each area is associated with a zone

- Trusted / Untrusted

- Internal / External

- Inside, Internet, servers, databases, screened

This simplifies security policies

- Trusted → Untrusted

- Untrusted → Screened

- Untrusted → Trusted

Attack Surface:

How many ways in?

- Doors, windows, basement

EVERYTHING can be a vulnerability

- Application code

- Open Ports

- Auth Process

- Human Error

Minimize the Surface

- Audit this code

- Block Ports

- Monitor Traffic

Connectivity:

Everything contributes to security

- Including Network security

Secure Network Configuring: Protect Physical data

Application Level Encryption

Network-Level Encryption

- IPSEC Tunnels, VPN

Intrusion Prevention system (IPS): 3.2

Watch network traffic

Intruders:

- Exploits against OS, apps, etc
- Buffer overflow, XSS, etc

Detection vs Prevention

- IPS (Intrusion Detection System) ALARM of Alert
- Prevention: Stop it before it gets in network

Failure Modes:

Monitoring Software can fail

Fail-open Config: When a system fails, data continues

Fail-close: When a system fails, data does not flow

Device Connections:

Active monitoring

- System is connected into
- Data can be blocked as it passes
- IP is commonly active

Passive Monitoring

- A copy of traffic is sent to IPS, not inline
- IDS design (not-inline) no it blocking

Active Monitoring

Manages traffic immediately identify & block

Passive monitoring:

Examine a copy of the traffic

No way to block (prevent traffic)

Quicker

Network Appliances: 3.2

Jump Server:

Access secure network devices

Highly secured and monitored

SST/Tunnel/VPN to the Jump Server

A Significant Security Concern

- Must be Perfect

Proxies:

Sits between users and the network

Receive the user requests and sends the request on their behalf

Useful for caching, interference, Access Control, URL Filtering, Content Scanning

Explicit: Application needs to know how to use a proxy

Transparent: Unknown or invisible to the user

Application Proxies:

- One of the simplest proxies is NAT (Network Address Translation)

- Network Level Proxy

Application Proxy: Understands the way a given application works

Some are multipurpose: HTTP, HTTPS

Forward Proxy:

An "internal Proxy"

- Commonly used to protect and control user access to the internet

Reverse Proxy:

Inbound traffic from the internet TO your internal services

- More Security
- Caching for internet requests

Open Proxy:

Third-Party, Uncontrolled Proxy

- Can be huge security concern
- Often used to circumvent existing security controls
- Anybody can use these!

Balancing the Load:

Load Balancer: Distributes work

- Multiple servers, invisible to end user

Large Scale Implementations

- Web Farms

Fault Tolerance

Active / Active load Balancing:

Configurable Load: Manage across server

TCP Offload: Protocol Offloading

SSL Offload: Encryption / Decryption

Caching: Fast Restore

Prioritization: QoS

Content Sanitizing

Active / Passive load Balancing:

Some Servers are active, others not

If an active server fails, the Passive takes its place

Sensors and Collectors:

Aggregate information from network devices

- Built in sensors / or separate devices

Sensors:

- Intrusion Prevention Systems, Firewall logs, auth logs, web logs...

Collectors

- Proxifier Sensors (IPS, IDS, SIEM Sensors, Syslog Collector)

Port Security: 3.2

We've created many authentication methods through the years

Username / Password

Commonly used on Wireless Network

EAP:

Extensible Authentication Protocol

- Auth framework

Many different ways to auth based on RFE sending

EAP integrates with 802.1X (IEEE Standard)

- Manages Auth Access

IEEE 802.1X

Port Based Network Access Control (NAC)

You don't get Network Access unless you authenticate it

EAP integrates with 802.1X

- Prevents Access until authentication succeeds

Used in conjunction with an auth database

- RADIUS, LDAP

IEEE 802.1X and EAP

Supplicant: Client

Authenticator: Device that Provides Access

Authentication Server: Verifies the Client Credentials

EAP Request + Response

Firewall Types: 3.2

The Universal Security Control

Standard issue:

- Home, Office, and in cars

Control the flow of network traffic

- All passes through

Control of inappropriate content/Email

- NSFW, Pornography, Anti-virus

Network - Based Firewall:

Controls traffic through use of more built options

OSI Layer 4 vs 7

Traditional vs. NGFW firewalls

Encrypt traffic

Must act on layer 3 (routers)

- Site of ingress/egress of network

UTM / All in One Security appliance:

Unified threat management device

- All in one appliance

- Malware inspection, Spam filter/Content inspection

- CSU/DSU, Router switch, IDS/IPS, Bandwidth Shaper, VPN endpoint

Next-Generation Firewall (NGFW)

The OSI Application Layer (7)

Can be called different names

- Application layer gateway
- Stateful Multilayer inspection
- Deep Packet inspection

Requires advanced tools

- Every packet must be analyzed & categorized

NGFWs

Network Based Firewall

- Control traffic flows based on applications
- Microsoft SQL Server, Twitter, Youtube

IPS:

Identify the application

App or service type

Content Filtering:

- URL filters
- Content Traffic by category

Web Application Firewall (WAF)

• Not like a normal firewall

• Applies rules to HTTP/HTTPS conversations

Allow or deny based on expected input

SQL injection prevention

Used in tandem with NGFWs often

Major focus of PCI DSS (Payment Card Industry Data Security Standard)

Secure Communication: 3.2

VPNs

Virtual Private Network

- Encrypted Private data traversing a Public Network

Concentrator

- Encryption/Decryption Access device

- Often Integrated into a Firewall

Many development options

- Specialized cryptographic hardware

Used with Client Software

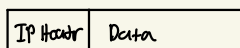
Encrypted Tunnel:

Keep data Private across Public Internet

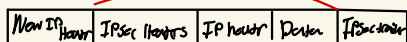
Encrypt Your data

- New headers & trailers

Original Packet:



Tunnel Mode:



SSL/TLS VPN (Secure Socket Layer VPN):

Uses Common SSL/TLS Protocol (tcp/443)

- Almost no firewall issues

TLS: Transport Layer Security

No big VPN clients

Authenticate users: No requirement for digital certificates or shared passwords like IPSec

Can run from a browser or VPN client

SSL/TLS VPN

On demand access from a remote device

- Software connects to a VPN concentrator

Some software can be configured as "Always-on"

Site-to-site IPSec VPN:

Always on

Firewalls often act as VPN concentrators

SD WAN:

Software Defined Networking in a Wide Area Network

Used for cloud based applications

Secure Access Service Edge (SASE)

Update Secure Access for cloud services

SASE: Next Gen VPN

Security services are in the cloud

SASE integrates on all clients

Selection of Effective Controls:

Many different security operations

VPN: IPsec tunnels for site-to-site access

SD-WAN: Manage connectivity to the cloud

SASE: Complete network & security solution

Data Types + Classifications: 8.3

Data Types:

Regulated: Managed by a third party

- Government laws + standards

Trade Secret: Organizations Secret formulas

- Often unique to an organization

Intellectual Property:

Patentable Invention

Copyright Laws

Legal Information:

Court records + documents

Judge / Attorney information

PII and other sensitive details

Usual? Store in many different systems

Financial information

- Bank info / Payments

Data Types:

Human Readable

Non-Human Readable: Encoded data, Barcode, images

Mix of Both

Classifying Sensitive Data:

Not all data has the same level of sensitivity

- Licensee log numbers vs. Health Records

Different Layers require different security & handling.

- Additional Permissions

- Restricted Access

Data Classifications:

Proprietary Data: Unique / Property of Organization

- May include trade secrets

PII: Personally Identifiable Information

- Data that points to you

- Name DOB

PHI: Protected Health Information

- Status of health, payments

Data Classifications:

Sensitive: Intellectual Property, PII, PHI

Confidential: Very Sensitive

Public / Unclassified: No restrictions

Private / Classified / Restricted

- May require a NDA Critical: Should ALWAYS be Accessed

States of Data: 3.3

Data at Rest:

The data is on a storage device

Encrypt the data

- Whole disk encryption

- Database encryption

- File- or folder level encryption

Apply Permissions: Access Control List

Data in Transit:

Data transmitted over the network

- Also control data in motion

Not much protection as it travels

- Switches, routers, devices

Network-Based Protection

- Firewall, IPS

Provide Transport Encryption

TLS (Transport Layer Security)

IPSec (Internet Protocol Security)

Data in Use:

Data is actively Processing in Memory

- System RAM, CPU registers & cache

The data is almost always deleted

The attackers can pick the deleted information out of RAM

Data in Sovereignty:

Information residing in a country or territory that must adhere to those laws

Laws may prohibit where data is stored

EU, US

Where is your data stored?

Geolocation

Location Details

Many ways to determine location

802.11, mobile providers, GPS

Can be used to merge data across

Limit Administrative state crosses sovereign user

Protecting Data: 3.3

Geographic Restrictions:

Network location

- Identity based on IP Subnet

- Can be difficult with mobile devices

Geolocation: Determine a users location

GPS: Mobile Devices, Very Accurate

802.11 Wireless, Less accurate

IP Address, Less Accurate

Geofencing: Automatically allow or restrict access

- Inside Facility only

- Black China

Protecting Data:

Primary job task

Data is everywhere

- On Storage device, on Network, in a CPU

Protecting the data: Encryption, Security Policies

Data Permissions

Encryption:

Encode information into unreadable data

- Original information is plaintext, encrypted form is ciphertext

This is a two way street

- Convert between one another

- Need proper key

Confusion: Resulting key is very different than plaintext

'Hello, world.' $\rightarrow$ W+95G9+R6B789+7-1fZ6...

Hashing:

Represent data as a short string of text

- A message digest, or fingerprint

One-Way Trip: Impossible to Recover original data

Verify a downloaded document is the same as the original

- Integrity

Can be a digital signature

- Authentication, Non-Repudiation + integrity

Collision unlikely

SHA-256 Hash:

256 bits / 64 Hex

Hi! → a6b29...

Hi. → f12785...

Similar results yield highly different outputs

Obfuscation:

Turns something very understandable to something extremely complex

Perfectly Readable Code → Nonsense

Both sets of code runs the same way

Helps prevent the search for security holes

• More difficult to determine what's actually

Code Obfuscation:

```
echo "Hello World";
```

↓

```
$... = Function
```

```
) $9
```

```
and
```

```
return ....
```

Performs same operation

Masking:

Type of Obfuscation

Pickens P11

**** * 4/175

May only be hidden from view

Substitution, Shuffling, masking

Tokenization:

Replace Sensitive Data with a Non-Sensitive Placeholder

SSN 266-12-1112 is now G41-G1-08594

Common with Credit Card Processing

• Apple Pay, Google Pay

No encrypting or hashing

No Mathematical relation

Canva derive one from another

Segmentation:

Many Companies use one large database

Separate the data, Store it into different banners

Sensitive Data should have stronger security

P11, function details

Permission Restrictions:

Control Access to account

- More than Username + Password

Authentication Process

- Password Policy

- Auth. Factor Policy

Resiliency: 3.4

Redundancy doesn't always mean availability

- May need to be powered on manually

HA (High Availability) Always on, Always Available

May involve different components working together

HA → Higher Costs

Server Clustering

Combine two or more servers

- Appears as one large server

Easily increase capacity and function

Load Balancing:

Load is distributed across multiple servers

- Unaware of other servers presence

- Can be different operating systems

The load balancer adds/removes servers

- Can identify server failures

Site Resiliency

Recovery site is prepped

A disaster occurs → Go to Recovery Site

Finally Return back to original site

Hot Site:

An exact replica: Duplicate everything

Stocked with identical hardware

Applications & Software are constantly updated

Flip switch & Forming Mass

Cold Site:

Empty building

No data

No people

Bring Your Own Stuff

Warm Site:

Middleground between the two

Big room with rack space

Geographic dispersion:

Physically distanced locations

- Hurricane, tornado, floods

Put in different state

Can be logistical challenges

- Transporting equipment, employees

Then must return

Platform Diversity:

Every OS contains security issues

Use many different platforms to spread/mitigate risk

Multi-Cloud Services:

Many cloud providers

If one cloud goes out, use another

Data is both geographically dispersed & cloud service dispersed

- Plan for every contingency

Continuity of Operations Plan (COOP)

Manual Processes: Paper records, Paper checks, Manual Transactions

Must be designed well before issue occurs

Capacity Planning: 3.4

Match supply to demand

• Not always obvious equation

Too much demand: Application slowdown / Outage

Too much supply: You're paying too much

Need balanced approach

People:

Some services require human intervention

Too little: Need to onboard

Too many: High costs

Technology:

Pick a scalable technology

Web Services

• Distribute

Cloud Services:

• Services on demand

• Unlimited resources (if you have the money)

Infrastructure:

The underlying framework

- App Servers, Networks, CPU, Settings

Physical Devices

- Purchase, Configure + Install

Cloud Services

- Immediate Scalability

Recovery Testing: 8.9

Test Yourself before an actual event

- Scheduled Update Sessions (Annual, Semi-annual, etc.)

Use Well defined rules of engagement

Very specific scenario

Evaluate response

- Document/Debrief

Tabletop Exercise:

Performing a full-scale disaster drill can be costly

- Time consuming

Many of the logistics can be determined through analysis

- Don't particularly have to go through disaster

Fail over:

A failure is often inevitable

We may be able to keep running, Plan for the worst

Create a redundant infrastructure to fail over to

Many devices do this automatically

Simulation:

Test with a Phishing attack

Password Requests, Data Breaches

Test on ALL your employees

- Who Clicked? More training

Parallel Processing:

Split a process through multiple (parallel CPUs)

- Single Computer with multiple CPU cores or multiple physical CPUs

Improve Performance

Improve Redundancy

- Quickly identify a faulty system

Backups: 3.4

Incredibly Important

- Recover important information and valuable data
- Plan for disaster

Many different implementations:

- Total Data Amount
- Type of backup
- Backup Media
- Storage Location
- Day of the Week

Onsite backups vs. Offsite Backups:

On-site Backups:

- No internet link required
- Data is immediately available
- Generally less expensive than off site

Off-site:

- Transfer data over WAN link
- Restoration can be performed from anywhere

Organizations use both

Frequency:

How often to backup?

- Every Week, day, hour?

This may be different between systems

- Some systems may not change much each day

May have multiple Backup sets

- Daily Weekly + monthly

Requires Significant Planning

- Multiple backup sets/media

Encryption:

A history of data is on backup media

- Some may be offline

This makes it easy for attacker

Protect data using encryption

- Must ensure you have ALL recovery keys

Especially useful for cloud storage

Snapshot:

Copy of Virtual Machine in one click

Take a Snapshot every 24 hours

Very fast Recovery, easy to perform

Recovery Testing:

Not enough to just backup, must ensure they work

Disaster recovery testing

- Simulate disaster recovery
- Restore from Backup

Confirm the restoration

Perform audit often

Replication:

An ongoing, real time backup

- Data synchronized on multiple devices

Always a copy somewhere

Data can be stored locally to all users

Data is recoverable easily

Journaling:

Power goes out while writing to storage

Recovery can be complicated

Before writing to storage, make a journal entry

- Fail-safe with Databases, Data, and Journals

Power Resiliency: 3.4

Power is the foundation of our technology

We don't make our own power

- Mostly provided by third parties

Ways to mitigate power issues

- Short-term OR long-term

UPS:

Uninterruptible Power Supply

- Short-term power supply
- Blackout, brownouts, surges

UPS Types:

- Offline/Standby UPS
- Line Interactive UPS
- Online/Double Conversion UPS

Features:

- Auto shutdown, Battery capacity, Phone line suppression
- Outlets

Generators:

Long term Power backup

- Runs off fuel

Powers on critical building (Size dependent)

May take a few minutes to get started

- Use battery UPS whilst the generator is starting